

PENETRATION TESTING REPORT

Mediroza General Hospital
Milestones 1, 2, 3 and 4

Prepared by	Lubanzi Fihla
Program	Networkwalks - Batch B083, Week 4
Target	https://medirozahospital.com
Engagement	Black-box penetration test
Authorization	Written permission granted
Reporting date	02 October 2026

Handling note: This report is written for the authorized Networkwalks educational engagement. Sensitive patient content, passwords, salary data and shareholder data are intentionally not reproduced in this GitHub-safe version.

Report Status and Evidence Basis

This document consolidates Milestone 1 and Milestone 2 work already discussed during the engagement and provides the Milestone 4 professional reporting structure. Statements are limited to the evidence currently available in the working notes and chat context. Where a screenshot, recovered value, exact payload, or final verification was not supplied, the report marks the item as an evidence placeholder rather than inventing a result.

Engagement scope and rules

- Client: Mediroza General Hospital.
- Target: <https://medirozahospital.com>.
- Testing model: black-box penetration testing in an explicitly authorized educational environment.
- Restrictions supplied by the brief: target domain only; no social engineering; no denial of service; no testing outside agreed scope.
- Overall milestone path: M1 initial access and three patient PDF reports; M2 PDF encryption analysis and content recovery; M3 critical data exposure; M4 professional report.

Evidence-handling approach

Evidence should be stored locally or in an instructor-approved private repository. A public GitHub repository should contain only sanitized notes and screenshots. Patient reports, recovered passwords, session material, employee salaries and shareholder details should not be committed publicly.

Milestone 1 - Initial Access

Objective

Assess the target website, identify exposed entry points and weaknesses around restricted content, demonstrate authorized access to the patient area, and retrieve the three confidential PDF lab reports required by the exercise.

Observed attack surface

The patient portal was identified at **/patient/login.php**. The portal presented Username and Password fields and stated that users sign in to view lab reports and results. The investigation also recorded an exposed-backup-headers evidence point identified as **M1-13 Exposed Backup Headers**.

Evidence trail

Item	Status / evidence
M1-13	Exposed Backup Headers - recorded as completed in the working progress.
Patient portal	Located at /patient/login.php; pre-authentication page observed.
M1-14	Restricted Area Access screenshot planned as M1-14-Restricted-Area-Access.png. Insert the actual screenshot only after verified access.
PDF deliverable	Three protected patient PDF reports were later present in the M2 working directory as patient_report_1.pdf, patient_report_2.pdf and patient_report_3.pdf.

Finding: Restricted patient resources exposed through web application weaknesses

Risk rating: High, provisional. Successful access to protected medical documents would create a significant confidentiality impact. The final rating should be confirmed against the actual exploit evidence and scope-approved proof.

Impact: Unauthorized disclosure of patient laboratory reports can expose sensitive personal and medical information and may create regulatory, contractual and reputational risk for the hospital.

Recommended remediation

- Enforce server-side authorization checks on every restricted resource, not only on the login page.
- Remove backup, temporary and legacy files from the production web root and prevent web-server access to backup-file extensions.
- Apply secure session management, including rotation after authentication, appropriate cookie flags and server-side validation.
- Log and alert on repeated access attempts to restricted resources and unusual document-download patterns.
- Store patient documents outside the directly accessible web root and serve files only through an authenticated authorization layer.

Evidence placeholder: Insert M1-14-Restricted-Area-Access.png and the sanitized filenames/hash values of the three retrieved lab reports before final submission.

Milestone 2 - Data Extraction

Objective

Analyze the encryption applied to the three PDF lab reports, select appropriate recovery methods, and document successful access as required by the authorized exercise.

Files observed in the working set

- patient_report_1.pdf
- patient_report_2.pdf
- patient_report_3.pdf

Encryption analysis recorded

The working evidence included use of **qpdf --show-encryption** against patient_report_1.pdf. The supplied output reported an incorrect password for that attempt, encryption revision **R = 3**, permissions value **P = -4**, and extraction permissions reported as allowed. The environment also confirmed **/usr/bin/pdf2john** was installed. These observations should be preserved as technical evidence, while recovered passwords themselves should remain outside any public report or repository.

Separate working evidence also showed **pdftinfo** being run successfully against patient_report_3.pdf using a recovered password. The visible metadata identified the document as a pathology report for a patient and showed author metadata. To minimize exposure, this report intentionally does not reproduce the patient name or recovered password.

Milestone 2 status

The course brief requires recovered contents of all three files with proof of access. The current report can document the analysis steps, but the final submission should only mark all three files as successfully recovered if the corresponding local evidence/screenshots confirm successful opening or extraction for each file.

Security implications

Password-protected PDFs should not be treated as a substitute for application authorization, access control, secure storage and key/password management. If protected documents can be downloaded first and attacked offline, the application has already lost control over access attempts and monitoring.

Recommended remediation

- Prevent unauthorized document download at the application and storage layers.
- Use strong, unique secrets generated and managed by an approved secrets-management process when document encryption is required.
- Avoid predictable or reusable document passwords derived from patient, employee or organizational information.
- Minimize sensitive metadata embedded in exported PDFs.
- Maintain access logging for document generation and download events, with retention appropriate to the organization policy.

Milestone 3 (M3) Technical Evidence Report

Target Entity: Mediroza General Hospital
Assessment Scope: Internal Data Leakage & Server Misconfiguration Audit
Exploitation Vector: Insecure Directory Indexing (CWE-548)
Target Domain: medirozahospital.com
Authorization: GRANTED

1. Executive Summary

Following the successful password audit of the encrypted clinical documents in Milestone 2, a comprehensive investigation into the infrastructure footprint of **medirozahospital.com** was initiated. Metadata analysis of the extracted pathology documents identified the target application footprint as *Mediroza CMS 1.4.2*, managed by user *j.malik*. Subsequent perimeter directory enumeration revealed a severe server misconfiguration: directory indexing was left enabled on the secure server within the **/old/** path. This exposure allowed unauthenticated structural navigation, resulting in the identification and retrieval of a full production database backup archive named **mediroza_db_backup_2019.sql**. Sifting through the schema structure exposed the entire human resources data registry and corporate equity configuration of the enterprise.

2. Technical Evidence: Exposed Employee Salaries

The database table staff contained 30 records detailing names, departments, personal emails, contact paths, South African National ID strings, and gross monthly salaries denominated in ZAR.

ID	Full Name	Department	Job Title	Salary (ZAR)
1	Dr. Rajesh Naidoo	Diagnostics Lab	Chief Pathologist	R138 000
2	Sarah Botha	Finance	Chief Financial Officer	R152 000
3	Dr. Johan van der Merwe	Management	Medical Director	R160 000
4	Dr. Anita Naicker	Cardiology	Consultant Cardiologist	R132 000
5	Dr. Ahmed Kara	Internal Medicine	Consultant Physician	R128 000
6	Dr. Yusuf Cassim	Emergency & Trauma	Senior Registrar	R74 000
7	Michael Roberts	Human Resources	HR Director	R96 000
8	Susan Pretorius	Human Resources	HR Officer	R32 000
9	Jameel Malik	IT	IT Systems Administrator	R58 000
10	Thabo Molefe	IT	Network Engineer	R46 000
11	Nomvula Khumalo	Emergency & Trauma	Registered Nurse	R34 000
12	Lerato Mokoena	Pediatrics	Registered Nurse	R33 000
13	Bongani Ndlovu	Cardiology	Registered Nurse	R35 000
14	Zanele Mahlangu	Theatre	Nursing Sister	R42 000
15	Kagiso Sithole	Pharmacy	Pharmacist	R61 000
16	Naledi Zulu	Pharmacy	Pharmacy Assistant	R26 000
17	Themba Nkosi	Radiology	Radiographer	R44 000
18	Palesa Radebe	Radiology	Radiographer	R43 000
19	Deepak Pillay	Diagnostics Lab	Lab Technologist	R41 000
20	Kavitha Govender	Diagnostics Lab	Lab Technician	R35 000
21	Dr. Suresh Moodley	Radiology	Consultant Radiologist	R130 000
22	Dr. Fatima Patel	Pediatrics	Pediatrician	R118 000
23	Nisha Singh	Rehabilitation	Physiotherapist	R48 000

24	Dr. Vikram Chetty	Theatre	Anaesthetist	R135 000
25	David Smith	Operations	Facilities Manager	R52 000
26	Karen O'Connor	Finance	Billing Administrator	R29 000
27	James Wilson	Operations	Security Supervisor	R27 000
28	Linda Fourie	Front Office	Receptionist	R19 000
29	Peter van Wyk	Supply Chain	Procurement Officer	R38 000
30	Andile Mbeki	Administration	Ward Clerk	R21 000

3. Technical Evidence: Shareholder Equity Structure

The database table shareholders revealed the exact allocation of the company's 1,000,000 corporate shares across internal founders and external holding entities.

ID	Shareholder Name	Share %	Shares Held	Share Class
1	Dr. Rajesh Naidoo	18.0%	180,000	Ordinary
2	Cedar Health Holdings (Pty) Ltd	15.0%	150,000	Ordinary
3	Dr. Johan van der Merwe	12.0%	120,000	Ordinary
4	Reddy Family Trust	11.0%	110,000	Ordinary
5	Thabo Molefe	10.0%	100,000	Ordinary
6	Sarah Botha	9.0%	90,000	Ordinary
7	Dr. Ahmed Kara	8.0%	80,000	Preferential
8	Naledi Zulu	7.0%	70,000	Ordinary
9	Michael Roberts	6.0%	60,000	Ordinary
10	Dr. Vikram Chetty	4.0%	40,000	Preferential

4. Strategic Mitigations

- 1. Enforce Strict Access Control & Disable Directory Listing:** Modify the production web server configuration (e.g., LiteSpeed context rules or Apache directives) by injecting Options -Indexes across all endpoints to break directory tracking options.
- 2. Strict Data Lifecycle Cleanup:** Implement scheduled automated scrub sequences to purge orphan or legacy database dumps (.sql, .bak, .tar.gz) from production-facing volumes immediately following structural synchronization window events.
- 3. Access Layer Demarcation:** Establish dedicated administrative landing interfaces separated entirely from target clinical production assets.

Milestone 4 - Professional Penetration Testing Report

01 Executive Summary

The authorized black-box assessment of the Mediroza General Hospital web environment identified weaknesses associated with access to restricted patient resources and protected PDF documents. The evidence gathered through Milestones 1 and 2 demonstrates that sensitive document exposure must be considered as a complete chain: web-layer authorization, file storage, downloadable document protection and information contained in document metadata all contribute to confidentiality risk.

The most important remediation priority is to prevent restricted documents from being obtainable without robust server-side authorization. Document encryption should be considered an additional control rather than the primary barrier protecting sensitive information.

02 Scope and Methodology

Scope: medirozahospital.com only, under written authorization supplied in the Networkwalks project brief. **Approach:** black-box reconnaissance, identification of exposed entry points, analysis of authentication/restricted-resource behavior, controlled evidence collection, PDF encryption inspection and validation of document access. **Tools evidenced in the working notes:** web browser, qpdf, pdftinfo, pdf2john and John the Ripper tooling environment.

03 Findings and Proof of Exploitation

ID	Finding	Severity	Evidence state
F-01	Restricted patient-resource exposure / authorization weakness	High (provisional)	M1-13 recorded; M1-14 screenshot to attach
F-02	Protected PDFs available for offline encryption analysis	High (provisional)	Three PDF filenames observed; encryption checks recorded
F-03	Sensitive document metadata may aid further investigation	Medium (provisional)	Metadata observed in M2; sanitize before public sharing

04 Risk Rating

Ratings are provisional because the complete evidence pack has not been supplied in this conversation. F-01 and F-02 are rated High on confidentiality impact if the documented access is confirmed. F-03 is rated Medium because metadata exposure can provide useful internal context and may enable chained attacks, but impact depends on the specific metadata disclosed.

05 Recommendations and Remediation

- Immediately validate authorization on every patient document and restricted route using server-side user/session checks.
- Remove publicly reachable backup and temporary artifacts; add deployment controls that prevent such files entering the production web root.
- Move sensitive files to non-public storage and broker every download through an authorization-controlled application endpoint.

- Review password-generation and encryption practices for exported reports; use strong unique secrets and avoid predictable values.
- Strip unnecessary PDF metadata during document generation.
- Implement security logging and alerting for authentication failures, enumeration patterns and unusual bulk document access.
- Retest each finding after remediation and retain sanitized before/after evidence.

Required attachments before instructor submission

- M1-14-Restricted-Area-Access.png after verified restricted access.
- Sanitized proof that all three required PDFs were retrieved.
- Local-only proof of successful access to each protected PDF for M2.
- Any M3 evidence required by the assignment should be added to the final report only after verified and should be redacted/sanitized for any public copy.

Report limitation: Milestone 3 findings are not included in this requested M1/M2/M4 version. The final M4 submission should integrate verified M3 results because the course brief defines M4 as the complete report covering every milestone.